

SQLMap Essentiels

Catégorie : ⚔ Offensif
Durée Estimé : 4 heures
Difficulté : Easy, Bien II

Aperçu de SQLMap :

SQLMap est un puissant outil open source écris en python qui automatise le processus de détection et d'exploitation des vulnérabilités d'injection SQL. Il prend en charge un très grand nombre de SGBD. et peux détecter et exploiter tous les types de SQLi connues... Il automatise le processus fastidieux de l'injection manuelle qu'il faut cependant maîtriser...

Prise en Main de l'outil :

L'outil à un affichage d'aide classique (-h) et plus avancé (-hh), mais comme toujours il faux consulter le wiki de l'outil.
L'option (-u) permet de fournir l'url à l'outil et l'option --batch est une automatisation total de l'attaque avec choix automatiques par défault pour chaque situation

Les Messages de Journals :

"target URL content is stable" : pas de changements majeurs entre les reponses dans le cas de requetes identiques continues. Cela est positif car ca rend plus facile de repérer les potentielles différences causées par une SQLi

"Get parameter id appear to be dynamique" : le parametre id est dynamique ce qui signifie que tout changement de sa valeur entraine un changement de réponses

NB : "L'est Heuristique de SQLMap = C'est basique". Bien que ce ne soit pas son objectif principal SQLMap peux tester la présence d'une XSS. Souvent beaucoup de données injectés se retrouvent dans les reponses les parasitants ainsi... SQLMap en fais automatiquement la détection...
Un message final indique dans quel fichier du system local SQLMap stocke les journaux de sessions et données de sortie pour une cible spécifique.

Il peux parfois être dur de fournir l'exacte bonne requete à SQLMap des elements indispensables comme les cookies de session peuvent avoir été mal transferé.
Une façon de faire est de sélectionner la requete cible dans la console du navigateur et de la copier comme curl pour ensuite la coller dans SQLMap

-- forms : rempli automatiquement les formulaire présent dans la requete pour tester les points d'injections
* : l'astérix sert à indiquer précisement à SQLMap ou performer des test d'injections SQL.
-r request.txt : lorsque les requetes sont un peu plus complexes il s'avère intéressant d'utiliser cet option puissante qui permet de copier une requete dans un fichier texte et de le passer à SQLMap
-- cookie = 'PHPSSID=053...' : pour les requetes personaliser passer un cookie à la requete
-- host='...' --refer='...' --user-agent='...' : pareil mais pour ces headers spécifiques...
-- random-agent : utiliser un user-agent aléatoire